

[Mã nhóm] · [Tên] — Báo cáo kiểm thử

Mẫu số 04 · Báo cáo kiểm thử (BCKT) — bắt buộc với nhóm tính năng có yếu tố **bảo mật, chấm điểm,** hoặc **quyền riêng tư**: K02 (SSRF guard), H07 (chống lạm dụng), H08 (quyền riêng tư), H10/H12 (rule engine và đánh giá), T04/T06 (entity và kiểm duyệt).

Copy file này, đổi tên thành **BCKT_<Mã>_<Ten_ngan>_<Nguoi>.md** .

Đây là tài liệu hội đồng đọc kỹ nhất trong phần bảo mật — viết cẩn thận.

Trường	Giá trị
Mã nhóm	[K02]
Tên	[SSRF guard & tầng fetch an toàn]
Người kiểm thử	[Tên]
Ngày chạy	[YYYY-MM-DD]
Phiên bản code	commit [abc1234]
Môi trường	[local / docker compose / VPS]

1. Mục tiêu kiểm thử

Một đoạn ngắn: đang chứng minh **điều gì** là đúng. Viết dưới dạng khẳng định kiểm chứng được.

[Ví dụ: "Chứng minh rằng không có đường nào khiến **worker** mở kết nối tới địa chỉ nội bộ — kể cả qua tên miền trở về IP nội bộ, qua chuỗi chuyển hướng, hay qua DNS rebinding."]

2. Chiến lược

Tầng	Kiểm cái gì	Công cụ
Unit	[Hàm isBlockedAddress() với từng dải IP]	[JUnit]
Tích hợp	[Toàn luồng POST /v1/scan/url với server giả]	[Spring Boot Test + WireMock]
Tấn công	[Các kỹ thuật vượt qua bộ lọc đã biết]	[Test thủ công + script]
Hiệu năng	[Độ trễ khi có timeout]	[đo bằng tay / k6]

3. Bảng ca kiểm thử

Mỗi dòng phải kiểm chứng độc lập được. Ai đọc bảng này cũng chạy lại được đúng ca đó.

#	Ca kiểm thử	Đầu vào	Kết quả kỳ vọng	Kết quả thực tế	Đạt
1	[Chặn metadata endpoint của cloud]	<code>http://169.254.169.254/latest/meta-data/</code>	<code>400 BLOCKED_INTERNAL_ADDRESS</code>	[như kỳ vọng]	✓
2	[Chặn loopback]	<code>http://127.0.0.1:8080</code>	<code>400</code>		✓
3	[Chặn dải mạng riêng]	<code>http://10.0.0.5</code>	<code>400</code>		✓
4	[Tên miền công khai trở về IP nội bộ]	domain có bản ghi A = <code>127.0.0.1</code>	<code>400</code> , chặn sau khi resolve DNS		✓
5	[Chuyển hướng về IP nội bộ ở bước 2]	URL công khai → <code>302</code> → <code>http://169.254.169.254</code>	<code>400</code> tại bước 2		✓
6	[Scheme không cho phép]	<code>file:///etc/passwd</code>	<code>400 UNSUPPORTED_SCHEME</code>		✓
7	[Phản hồi quá lớn]	trang trả 500 MB	Hủy ở ngưỡng, không tràn bộ nhớ		✓
8	[Phản hồi quá chậm]	server treo 60 giây	Timeout, không giữ luồng		✓
9	[Đường đúng]	<code>https://example.com</code>	<code>200</code> + kết quả quét		✓

Ký hiệu: ✓ đạt · ✗ không đạt · ⚠ đạt một phần (giải thích ở mục 5)

4. Cách chạy lại toàn bộ

```
# Ví dụ
cd services/worker
mvn test -Dtest=SsrfGuardTest

# Ca cần server giả:
docker compose -f infra/docker-compose.test.yml up -d
mvn verify -Pintegration
```

Đầu ra mong đợi: `[ Tests run: 24, Failures: 0, Errors: 0, Skipped: 0 ]`

5. Ca không đạt hoặc đạt một phần

Không giấu. Ghi ra và nói rõ định làm gì. Bỏ mục này nếu tất cả đều đạt.

#	Ca	Sai ở đâu	Nguyên nhân	Xử lý	Hạn
[5 1]	[Redirect nội bộ]	[Bước 3 trở đi không kiểm tra lại]	[Vòng lặp redirect chỉ kiểm tra IP ở lần đầu]	[Chuyển kiểm tra vào trong vòng lặp]	[23/10]

6. Số liệu (nếu là nhóm chấm điểm hoặc hiệu năng)

Bỏ mục này nếu không áp dụng. Với H12 thì đây là mục chính của cả báo cáo.

6.1. Chất lượng phân loại

Cấu hình	Precision	Recall	F1	Độ trễ trung vị	Số mẫu
Chỉ rule					
Chỉ LLM					
Kết hợp					

6.2. Ma trận nhầm lẫn

	Dự đoán: lừa đảo	Dự đoán: an toàn
Thực tế: lừa đảo	[TP]	[FN]
Thực tế: an toàn	[FP]	[TN]

6.3. Phân tích case sai

#	Đầu vào	Nhãn thật	Hệ thống trả	Vì sao sai	Sửa được không
1	[...]	[scam]	[SAFE]	[Không có từ khoá nào khớp, câu viết rất tự nhiên]	[Cần lớp LLM — thuộc H11]

7. Kết luận

Câu hỏi	Trả lời
Số ca chạy	[24]
Số ca đạt	[24]
Nhóm tính năng này đủ điều kiện nghiệm thu chưa?	☐ Rõi ☐ Chưa — vì [...]
Rủi ro còn lại	[...]
Kiến nghị	[...]

Người kiểm thử: [Tên] · Ngày: [YYYY-MM-DD] · Mẫu: BCKT v1.0